# Code Review Report

Prepared by FusionHawk for Anarock Property Consultants Pvt. Ltd. | Date: 2026-10-16 | Repository fusionhawk/Anarock, main @ fcdc286 | Basis: OWASP Code Review Guide, ISO/IEC 25010, CWE | Build, lint and install run in a clean sandbox this run

## 1. Executive summary

**The code does not build and the Production Slate deployment has failed.** next lint reports one error (list-your-property/page.js:993) that stops next build; npm ci cannot install because package-lock.json is out of sync; the Catalyst Production Slate deployment of 2026-10-14 failed after 13 minutes (the build log is not retrievable through the connector, so the lint failure is a plausible, unconfirmed cause). The application is about 28,265 lines (excluding 3,969 lines of generated shadcn/ui components) with no automated tests, no CI, and large amounts of dead code. Core lead capture works in the live CRM (7 'Listing Platform' leads since 2026-09-22), but listing and detail pages are client-rendered, so the SEO scope is not met.

## 2. Build, install and lint results (executed in the clean sandbox)

| Check | Result | Detail | Evidence |
|---|---|---|---|
| npm ci (Node 22.22.0, npm 10.9.4) | FAIL | EUSAGE: lock file out of sync; Missing @emnapi/core@1.11.3 and @emnapi/runtime@1.11.3 | 02_npm_ci_audit.log |
| npm install (workaround, scratch copy) | PASS | 395 packages installed in 14 s; deprecation warnings for eslint 8.57.0, glob 7/10 | 03_lint_build.log |
| next lint | FAIL | 1 error: react/no-unescaped-entities at src/app/list-your-property/page.js:993:56; 4 warnings (3 x <img> instead of next/image: Footer.js:70, Navbar.js:711, HomePage.js:1379; 1 missing hook dependency Navbar.js:326) | 03_lint_build.log |
| next build | FAIL | Compiled successfully, then 'Failed to compile' at the lint gate (same error). No production bundle can be produced | 03_lint_build.log |
| npm audit | FAIL | 13 vulnerabilities (1 critical, 10 high, 2 moderate) | 02_npm_ci_audit.log |
| Type checking | Not available | Project is JavaScript (jsconfig.json only); no TypeScript or typecheck script | - |
| Unit / integration tests | Not available | No test files, no test script, no test framework in package.json | git ls-files |

## 3. Codebase metrics (measured this run)

| Metric | Value | Comment |
|---|---|---|
| Application source (src, js/jsx) | 32,234 lines | 28,265 excluding src/components/ui (generated shadcn components) |
| Largest files | properties/route.js 2,341; lead3/route.js 1,476; leads/route.js 1,044; HomePage.js 2,365; catalyst.js 787 | Several files carry the logic of whole modules; hard to review or test |
| Commented-out code | properties/route.js: 1,221 of 2,341 lines (52%); catalyst.js: 273 of 787 lines | Dead code (CWE-561) hides the real implementation and old credentials flow; git already holds history |
| Lead endpoints | 3 (leads 1,044 lines, lead2 512, lead3 1,476) | Overlapping responsibilities; different validation per endpoint (see S-02) |
| console.* statements | 193 in 27 files | Includes raw error objects and user search text (S-13) |
| Empty files | src/lib/propertyService.js (0 lines) | Dead module |
| Direct dependencies | next 14.2.35, react 18, framer-motion, radix-ui, zcatalyst-sdk-node, tailwind 3, eslint 8 | Next 14 line has critical advisories (S-01) |

# 4. Findings register

| ID | Severity | Title | Detail | Standard / CWE | How verified | Recommendation |
|---|---|---|---|---|---|---|
| C-01 | High | **Build gate broken** | next build fails on a lint error (list-your-property/page.js:993: unescaped apostrophe). Combined with the failed Production Slate deployment (Catalyst deployment 16250000000011003, build 16250000000011007 Failed after 13m8s on 2026-10-14) there is no working Production site. | CWE-710; ISO 25010 Reliability/Portability | Executed next build (03_lint_build.log); Slate status via connector | Fix the entity, re-run build in CI, redeploy Production; investigate the Slate build log. |
| C-02 | High | **Non-reproducible installs** | package-lock.json is out of sync with package.json; npm ci fails. Slate's install_command is `npm install`, so every deployment resolves new versions. | CWE-1104; ISO Maintainability | Executed npm ci | Regenerate and commit the lockfile; use npm ci in Slate and CI. |
| C-03 | Medium | **Listing and detail pages are client-rendered (SEO scope not met)** | /properties page.js renders <Suspense> with 'Loading properties...' and a client component; the server HTML contains no listings. Home page is `use client` and imports a 2,365-line component from src/pages/HomePage.js. SoW 3.3 requires SSR/SSG/ISR of listing and detail pages. | ISO Functional suitability; SoW 3.3 | Executed: server HTML check in run_api_tests.sh (FAIL); code read | Fetch listings server-side in a server component with ISR; keep only interactive filters on the client. |
| C-04 | Medium | **Canonical URL wrong on every page** | layout.js sets alternates.canonical = '/' globally; pages that do not override it (properties, detail, services, KYC, list-your-property) all declare the homepage as canonical. /shortlist canonicalises to /wishlist, which returns 404. | ISO Functional suitability; SEO | Executed: curl of 5 pages, canonical = http://localhost:3111 (08 log) | Set per-page canonical in generateMetadata. |
| C-05 | Medium | **Sitemap and robots defects** | sitemap.js lists 'services&tools' (unescaped '&' makes sitemap.xml invalid XML; ZAP logged a parse error; the URL 404s) and 'list-property' (404; real route is /list-your-property); no property or KYC URLs are listed; robots.txt disallows /wishlist, which does not exist. | ISO Functional suitability; CWE-116 | Executed: sitemap URL resolution (2 x 404), ZAP spider error | Generate the sitemap from real routes and Data Store rows; escape XML. |
| C-06 | Medium | **Legal and information pages missing** | Footer links /aboutus, /privacy-policy, /rera and /terms-of-use all return 404. SoW 5.1 requires About, Contact, Privacy Policy and Terms pages (privacy page is also needed for the cookie banner and DPDP compliance). | ISO Functional suitability; legal | Executed: link crawl (4 x 404) | Add the pages or remove the links. |
| C-07 | Medium | **Dead code and file size** | 52% of properties/route.js and 273 lines of catalyst.js are commented-out code; HomePage.js is 2,365 lines; leads/lead3 are 1,000+ line single functions. | CWE-561, CWE-1121; ISO Maintainability (modularity, analysability) | Measured (section 3) | Delete dead code, split into modules, extract shared lead logic. |
| C-08 | Medium | **Three overlapping lead endpoints with different guards** | leads (validation, honeypot, rate limit), lead2 (none) and lead3 (as leads plus subform) each re-implement token refresh, duplicate handling and responses. The weakest one is what an attacker uses (S-02). | CWE-1041 (redundant code); ISO Maintainability/Security | Code read; runtime tests | One shared handler with schema validation (e.g. zod) and one throttle. |
| C-09 | Medium | **In-memory state for caches and rate limits** | Rate limit, property cache, city/micromarket/KYC caches live in module-level Maps/globalThis. On serverless/multi-instance hosting each instance has its own state and memory growth is unbounded for the limiter. | CWE-770; ISO Reliability/Performance | Code read (leads/route.js:121, cache.js, propertiesCache.js) | Use Catalyst Cache or the gateway for throttling; bound caches. |
| C-10 | Low | **Stray Pages-Router route** | src/pages/HomePage.js sits in the Pages Router directory of an App Router project, so Next serves it as a second page at /HomePage (HTTP 200) with duplicate home content. | ISO Maintainability; SEO duplicate content | Executed: curl /HomePage = 200 | Move the component to src/components/home/ and import it. |
| C-11 | Low | **Deployment hygiene** | catalyst.json points at a Windows path (D:\Catalyst\anarock) and registers one Slate app ('nextjs'), while Catalyst holds two Development apps (Anarock, nextjs) and a failed Production app (anarock, upload type, root ./Catalyst). Production Slate has no environment variables configured. | ISO Portability/Maintainability | catalyst.json; connector (10b log) | One app per environment, built from the repository, with env vars set in Catalyst. |
| C-12 | Low | **Boilerplate documentation** | anarock/README.md is the unmodified create-next-app text; no .env.example, CONTRIBUTING, SECURITY, LICENSE or CODEOWNERS. | ISO Maintainability (analysability) | git ls-files | Replace with project docs (root README is accurate and maintained). |
| C-13 | Low | **Unvalidated third-party responses** | exchange-rates and location routes pass upstream JSON through without schema checks; location and exchange-rate failures return HTTP 200/502 inconsistently. | CWE-20; OWASP API10 | Code read; runtime tests | Validate with a schema and use consistent status codes. |
| C-14 | Low | **Fonts fetched from Google at build time** | next/font/google downloads Inter during build/dev; offline or restricted build environments fall back silently (seen in the sandbox log). | ISO Portability/Reliability | Dev server log | Self-host the font. |

| ID | Severity | Title | Detail | Standard / CWE | How verified | Recommendation |
|---|---|---|---|---|---|---|
| C-15 | Low | **Seed data presented as live** | Catalyst Stats table (market stats widget) has hard-coded column defaults 850,000,000 / 145,000,000 / 98,000,000 / 42,000,000 and one row; KYC table has default quarter 'Q4 2026'. If the row is not maintained the homepage shows unsourced numbers. | ISO Functional suitability | Data Store column metadata via connector | Add an owner/process for Stats and show an 'as of' date. |

Security-specific findings (S-01 to S-18) are in the Security report; they are not repeated here.

# 5. ISO/IEC 25010 quality assessment

| Characteristic | Rating | Evidence |
|---|---|---|
| Functional suitability | Partial | Search, filters, compare, wishlist, currency/area switch, lead capture and KYC pages exist; AI search, SalesIQ, PageSense, GA4, view scoring absent; listing SSR missing (C-03); legal pages 404 (C-06) |
| Performance efficiency | Concern | Whole catalogue (395 rows) can be returned in one response; in-memory caches; 2,365-line client component for home; 3 un-optimised <img>; page loads 1.1-2.3 s on the dev server |
| Compatibility | Good | No horizontal scroll at 1366px and 375px on all 8 pages; no console errors in the browser tests |
| Usability / accessibility | Concern | axe-core WCAG 2.1 A/AA: 4 of 8 pages (desktop) and 3 of 8 (375px) have critical/serious violations (section 6); users see raw internal errors when the backend is unavailable |
| Reliability | Poor | Build fails; Production deployment failed; error handling returns 500/200 inconsistently; cache and limiter state per instance |
| Security | Poor | See Security report: 1 critical, high and medium findings; no headers; open sign-up |
| Maintainability | Poor | Dead code 52% of the largest route; three duplicated lead handlers; no tests, no CI, no types; stale docs in subfolder |
| Portability | Concern | Windows path in catalyst.json; npm ci fails; Google font download at build |

# 6. Accessibility results (axe-core 4.10.2, WCAG 2.1 A and AA, Playwright 1.56.1)

| Viewport | Page | Result | Violations (rule(impact, nodes)) |
|---|---|---|---|
| desktop 1366px | / | FAIL | aria-required-parent(critical,2), color-contrast(serious,3) |
| desktop 1366px | /properties | FAIL | select-name(critical,2) |
| desktop 1366px | /shortlist | PASS | none critical/serious |
| desktop 1366px | /compare | PASS | none critical/serious |
| desktop 1366px | /list-your-property | FAIL | color-contrast(serious,10), select-name(critical,1) |
| desktop 1366px | /services | PASS | none critical/serious |
| desktop 1366px | /kyc/city/delhi | FAIL | color-contrast(serious,2) |
| desktop 1366px | /properties/1/test-property | PASS | none critical/serious |
| mobile 375px | / | FAIL | aria-required-parent(critical,2), color-contrast(serious,3) |
| mobile 375px | /properties | PASS | none critical/serious |
| mobile 375px | /shortlist | PASS | none critical/serious |
| mobile 375px | /compare | PASS | none critical/serious |
| mobile 375px | /list-your-property | FAIL | color-contrast(serious,5), select-name(critical,1) |
| mobile 375px | /services | PASS | none critical/serious |
| mobile 375px | /kyc/city/delhi | FAIL | color-contrast(serious,2) |
| mobile 375px | /properties/1/test-property | PASS | none critical/serious |

Defects: aria-required-parent on the home page (2 nodes), select-name (unlabelled selects) on /properties and /list-your-property, and colour contrast on home, list-your-property and KYC pages. Only critical and serious impacts are gated; moderate and minor issues are listed in 09_browser_tests.log ('all:' list). Automated tools find roughly a third of WCAG issues; manual keyboard and screen-reader testing was not done.

# 7. Register of missing items

| Area | Missing item | Status | Note |
|---|---|---|---|
| Catalyst Functions | CRM sync, Stratus image push, Gemini attribute generation, validation routing, view scoring, revalidation, lead capture function | Missing | Only stratus_upload exists in Catalyst: is_deployed=false in both environments, source not in the repo; lead capture lives in Next.js API routes |
| Catalyst Search | Full-text and faceted search service | Missing | No code or configuration; search is in-memory over the Data Store cache |
| API Gateway | Rules, auth and throttling in front of app APIs | Missing | One rule (stratus_upload, ANY); SoW 3.2 requires gateway to secure endpoints |
| Scheduled jobs | Sitemap regeneration, stale-content revalidation | Missing | No cron jobs or job pools in Catalyst |
| Tests | Unit, API, E2E tests; test script | Missing | None in repo; this assessment's scripts in reports/evidence/ are the only automated checks |
| CI/CD | GitHub Actions or Catalyst pipeline with lint, build, audit | Missing | No .github, no pipelines; build failures reach Slate unnoticed |
| Config | .env.example, documented env variables per environment, secrets rotation notes | Missing | Root README documents variables; Production Slate has none set |
| Security headers / CSP / CAPTCHA | headers(), CAPTCHA on lead forms | Missing | S-06, S-02 |
| Monitoring and alerting | Error tracking, uptime, Catalyst log alerts | Missing | Application logs for the Slate app returned nothing for the last 7 days |
| Analytics and engagement | GA4/GTM, Search Console, SalesIQ, PageSense | Missing | No scripts or configuration in the code |
| Legal / content pages | About, Contact, Privacy Policy, Terms, RERA | Missing | Footer links 404 (C-06) |
| Documentation | API docs, architecture, runbook, data-flow for CRM -> Stratus -> Data Store sync | Missing | Sync mechanism that populates 395 Data Store rows is undocumented |
| Repo governance | LICENSE, SECURITY.md, CODEOWNERS, branch protection | Missing | GitHub Advanced Security off |
| Structured data | RealEstateListing / Product / Offer JSON-LD | Missing | Only Organization and breadcrumb JSON-LD exist |

# 8. Limitations

- Review covers the active code in the repository; Catalyst Function source (stratus_upload) and any CRM-side workflows or custom functions are not visible through the connectors and were not reviewed.

- Runtime behaviour that needs Catalyst/Zoho credentials (listing data, detail pages, lead creation end to end) was not executed. No production writes were made. No application code was modified.

- Accessibility results are automated (axe-core) only.